



VUKA · GKHACK26

SDLC Gap Analysis

What is wrong with our own process, written by us

You are not alone. You don't have to ask.

VIGIL the person	UMOJA the street	KHAYA the property	ANCHOR the record
----------------------------	----------------------------	------------------------------	-----------------------------

VUKA — SDLC Gap Analysis

"What did I miss?" — answered as a register, not as reassurance

Document	21-VUKA-SDLC-Gap-Analysis.md
Version	1.0 · 19 August 2026
Question it answers	Which lifecycle artefacts a complete engineering submission needs, which ones existed, which ones now exist, and which ones are still missing
Companions	19-VUKA-System-Architecture.md · 20-VUKA-SDLC.md

1 · The short answer

The submission pack was **strong on argument and thin on engineering apparatus**.

Eighteen documents covered the concept, the business case, the blockchain fit, the autonomy position, the naming, the repository audit and the honesty ledger — and covered them unusually well. What was missing was almost everything a reviewer uses to check that the argument corresponds to a real system: **no C4 views, no sequence diagrams, no data model, no traceability matrix, no test strategy, no threat model per boundary, no compliance matrix, no SLOs, no DR plan, no sustainability plan, and no impact framework** — the last two being *explicitly named by the 2026 theme*.

Put bluntly: **the pack could persuade a judge but could not be audited by one**, and this year's theme asks to be audited.

That has now largely been closed. §3 is the full register. §4 is what is still open, ranked, with honest effort estimates.

2 · What the event actually scores, and where the gaps landed

2.1 The six mandated deck sections

Mandated section	Was it covered?	Where it is now
Problem Statement	✅ Strongly — the coercion thesis is the best asset in the pack	Architecture Part I
Solution	✅ Strongly	Architecture Part I, III
Technology Readiness Level	⚠️ Template says TRL 3; we can evidence TRL 5 and had not written the evidence down	Architecture §11.1 — the ladder, the evidence table, and the four reasons we are not TRL 6
Technological Architecture	⚠️ One HTML page. No C4, no sequences, no data model, no deployment view	Architecture Parts III, IV, VI, VIII — 46 diagrams
User Journey Story	✅ Covered in prose	Architecture §4.2 adds the timed sequence diagram version
Go-to-market strategy	✅ Covered	Business case; sustainability §11.4 strengthens it

The weakest mandated section was Technological Architecture, and it is the one this cycle fixed.

2.2 The four scoring criteria

Criterion	Gap found	Status now
Team Composition /10	Previously: three builders, no gender variety, UI/UX shared rather than owned. Scored on skills variety, sector background and/or gender variety	Closed. Seven builders across four universities, gender variety present, dedicated frontend and security-design roles. Current gaps in <code>docs/TEAM.md</code> §3
Innovation & Creativity /10	The genuinely novel ideas (conflict-suppressed fusion, precedence-not-immutability, refusal-as-a-tested-requirement) were buried in prose	Surfaced as named, diagrammed mechanisms
Progress of solution profile /10 — <i>names wireframing and architecture outlook</i>	⚠️ Architecture outlook was thin. Wireframes are not committed anywhere	Architecture: closed. Wireframes: still open — §4 item 1
User Journey Story /10	Prose only	Sequence diagram with real timestamps added

3 · The artefact register

Legend: ✅ now exists · 🏗️ partial · ❌ still missing · (where) = location

A · Architecture and design

#	Artefact	Before	Now	Where
1	System architecture document	✗ one HTML page	✓	19-...-Architecture.md
2	Design process / systems design approach	✗	✓	Part II
3	C4 Level 1 — system context	✗	✓	§3.1
4	C4 Level 2 — containers	✗	✓	§3.2
5	C4 Level 3 — components, all four layers	✗	✓	§3.3–3.6
6	Dependency rules / layering constraints	✗	✓	§3.8
7	Sequence diagrams — 6 scenarios	✗	✓	§4.2–4.7
8	State machines — escalation and entity lifecycle	✗ prose	✓	§4.8
9	Latency budget decomposition	✗	✓	§4.9
10	Architecturally significant requirements (ASR-1...10)	✗	✓	§2.5
11	Quality attribute scenarios (ATAM, QA-1...10)	✗	✓	§2.6
12	Architecture trade-offs, with the cost stated	✗	✓	§2.7
13	Deployment topology and environments	✗	✓	Part VIII
14	Scaling path	✗	✓	§8.6

B · Data architecture

#	Artefact	Before	Now	Where
15	Logical data model / ERD	✗	✓	§6.2
16	Data dictionary — including a "what it is <i>not</i>" column	✗	✓	§6.3
17	Data classification tiers T0–T3	✗	✓	§6.1
18	Data-flow diagram with trust boundaries	✗	✓	§6.4
19	Retention schedule	✗ <i>(this was gap G-3)</i>	✓ specified	§6.5
20	What is never stored — stated explicitly	✗	✓	§6.6
21	Deletion semantics	✗ ADR only	✓	§6.7
22	Schema evolution policy	✗	✓	§6.8, §11.3

C · Security and privacy

#	Artefact	Before	Now	Where
23	Adversary model — including the vendor		✓	\$9.1
24	STRIDE per trust boundary	✗	✓	\$9.1
25	OWASP Top 10 mapping		✓	\$9.1
26	Abuse-case suite AB-1...AB-12	✗	✓	\$10.4
27	POPIA compliance matrix, section by section	✗	✓	\$9.2
28	Other applicable law — RICA, ECT Act, PSiRA, CPA	✗	✓	\$9.2
29	Identity, authentication, authorisation model	✗	✓	\$9.3
30	Key custody and rotation		✓	\$7.4
31	Secrets management policy		✓	SDLC §10
32	SSDLC phase mapping	✓ existed	✓ referenced	09-...-SSDLC.md , SDLC §7

D · Verification

#	Artefact	Before	Now	Where
33	Test strategy and pyramid	✗	✓	Part X, SDLC §8
34	Requirements traceability matrix — F/N/E	✗	✓	\$10.3
35	Invariant tests E1-E9 — refusals as tests	principle only	✓	\$10.2
36	Mandatory-test areas	in CLAUDE.md	✓	\$10.2
37	Referee scripts, named		✓	\$10.5
38	CI gates		✓	\$10.6, SDLC §9
39	Test data policy	✗	✓	SDLC §8
40	Bias evaluation plan	✗	✓ plan (⚠️ not run — G-9)	\$10.5

E · Lifecycle and operations

#	Artefact	Before	Now	Where
41	Full SDLC document	✗	✓	20-VUKA-SDLC.md
42	Gate entry/exit criteria	dates only	✓	SDLC §2
43	RACI	✗	✓	SDLC §3.2
44	Definition of Ready / Done	✗	✓	SDLC §6.2–6.3

#	Artefact	Before	Now	Where
45	Branching, release and rollback		✓	SDLC §9
46	Configuration and environment policy	✗	✓	SDLC §10
47	Deployment runbook	✗	✓	SDLC §11.1
48	Observability, SLIs, SLOs, error budgets	✗	✓	§9.4
49	Incident response with severity scale	✗	✓	SDLC §11.3
50	Backup, DR, BCP — RPO/RTO	✗	✓	SDLC §11.4
51	Degradation matrix per failure mode	principle	✓	§9.5
52	Change control, including the two-key rule		✓	SDLC §12
53	Maintenance and evolution	✗	✓	SDLC §13
54	Documentation standards		✓	SDLC §14
55	Templates — ADR, PR, incident, model card	✗	✓	SDLC §17

F · Product, impact and readiness

#	Artefact	Before	Now	Where
56	TRL ladder with evidence, and why not higher	asserted	✓	§11.1
57	Roadmap beyond the event		✓	§11.2
58	Versioning and interface lifecycle	✗	✓	§11.3
59	Sustainability plan — financial, operational, environmental	✗ theme-mandated	✓	§11.4
60	Measurable impact framework	✗ theme-mandated	✓	§11.5
61	Accessibility, literacy, language, low-end devices	✗	✓ specified	§9.7
62	Architecture risk register — distinct from open gaps	✗	✓	§12.1
63	Open-gap register, published	✓ existed	✓ + 2 new	§12.2
64	Honesty ledger with a swap table	list only	✓	§12.3
65	ADR index	✗ <i>(25 ADRs referenced, never listed)</i>	✓	§12.4
66	Glossary and notation		✓	Appendix C, D
67	"How to check this document rather than believe it"	✗	✓	Appendix E

Register total: 67 artefacts. 41 did not exist in any form before this cycle. 5 remain open — \$4.

4 · 🚨 What is STILL missing

Ranked by return before 25 August. Effort figures are 📌 estimates.

1 · Wireframes committed as images — HIGH · the rubric names it

The scoring criterion "*Progress of solution profile*" explicitly names **wireframing**. **14 exported screen specifications already exist** — and they are not committed anywhere a judge can see them.

Why it matters	This is free marks currently being left on the table. The work is done; only the publishing is missing
Action	Commit the 14 screens to docs/wireframes/ , add an index page with one line per screen naming which user journey step it serves
Effort	📌 1–2 hours
Owner	A

2 · Model provenance and licence register — HIGH · a repeat of a mistake we already made

We ship or integrate **YOLOv8**, **YAMNet**, **ArcFace/InsightFace** and **EasyOCR**. There is no register recording each model's source, version, sha256, and **licence**.

🚨 **This one deserves attention beyond the paperwork.** Some widely used pretrained weights in this exact stack carry terms that are incompatible with a permissively licensed public repository or with commercial use — **Ultralytics YOLOv8 is distributed under AGPL-3.0 with a separate commercial licence, and several InsightFace pretrained models are released for non-commercial research use only.** Those are the terms to verify against the actual files we ship, not assume.

We have already had one licensing exposure this cycle (G-7, a third party's dataset in a public MIT repository). Having a second one found by a judge, in the same submission, would do more damage than the first — because the first was a mistake and the second would look like a pattern.

Action	A table per model: name · version · source URL · sha256 · licence · commercial-use position · where it runs. Then reconcile against our repository licence
Effort	📌 2–3 hours to compile, plus whatever the licence reading forces
Owner	A, with C on the commercial position

3 · Model cards — MEDIUM

The template is in 20-VUKA-SDLC.md §17.4. The cards themselves are not written. The row that matters is **"Known limitations / demographic performance"**, where "*not measured*" is a valid and required answer today.

■ 2 hours · Owner A · Pairs naturally with item 2.

4 · OpenAPI specification — MEDIUM

The contract is frozen and written in prose. A machine-readable `openapi.yaml` would let a judge or a partner explore it without reading our code, and would let contract tests be generated rather than hand-written.

■ 3–4 hours · Owner B.

5 · Operator training and duty material — MEDIUM · and it is a safety control

The human gate is the central safety mechanism in the system. **There is no material describing what an operator is trained to do**, what "verify" means in practice, what evidence is sufficient, how to escalate, or how to co-sign.

An untrained human gate is a rubber stamp, and a rubber stamp is functionally the automated decision we refused to build. This is not administrative — it is the difference between D6 being real and D6 being decorative.

■ 3 hours · Owner A/B.

Blocked by design, not by neglect

Item	Blocked until	Gap
Reliability diagram + ECE	G4 — needs real data	G-1
Bias evaluation results	G5	G-9
Independent penetration test	G5	G-8
Hardware validation	Fabrication	G-10
Member privacy notice, terms, DPA	Pilot, with counsel	—
POPIA Information Officer registration	Before pilot	⚠ a concrete, cheap, statutory step worth diarising now

5 · The five highest-return actions before 25 August

#	Action	Return	Effort
1	Close G0. Rotate the three secrets, change the reused password, purge git history , install the pre-commit hook and CI gate, remove the third-party dataset, split both READMEs into <i>Built / Designed, not built</i>	Everything else is worthless without it. A README advertising six technologies that are not in the code is the first thing a judge reads	Known
2	Recruit a fourth member — most valuable if she brings design or security-sector background, closing two scoring lines at once	Team Composition is a full 10 points and is the only criterion we currently cannot argue our way through	Days
3	Commit the 14 wireframes	The rubric names wireframing. The work exists; only publishing is missing	■ 1–2 h
4	Compile the model licence register	Prevents a second licensing finding in the same submission	■ 2–3 h
5	Rebuild the deck against Architecture §11.1, §11.4, §11.5	TRL evidence, sustainability and measurable impact are theme-mandated and were the three thinnest sections	■ 3 h

6 · What did not need fixing

A gap analysis that only lists faults is a bad analysis. Five things in the original pack were genuinely strong and should not be rewritten in the name of consistency:

The problem statement	The coercion thesis — <i>the authentication factor and the asset now sit in the same object, in the victim's own hand, secured by a biometric that can be compelled</i> — is the sharpest paragraph in the entire pack. It should open the deck
The honesty ledger	Deciding in advance which claims you refuse to make is rare, and it is the moat
The refusal to relitigate	Sixteen locked decisions with an amendment protocol is why a distributed team can move at all
The open-gap register	Publishing your own weaknesses before anyone asks is the highest-trust move available, and it was already there
The lineage	VUKA and BEACON were built in July 2026 for a different programme, with a <code>CLAUDE.md</code> from that month describing the two-layer architecture. ANCHOR is the third layer of a plan published before this hackathon existed. The commit history is the capability statement, and it is verifiable

7 · The one-sentence version

The argument was already good. What was missing was the apparatus that lets someone check the argument — and for a product whose entire thesis is that it can be verified rather than trusted, that apparatus was not documentation overhead. It was the product's central claim, undocumented.